

SQL Injection

Users.php

The screenshot shows a web browser interface for a collection named "My Collection" with a sub-collection "Get data". The URL bar displays the request: `GET http://localhost/cinema_booking/api/users.php?user_id=1' OR '1'=1`. The "Params" tab is active, showing a query parameter `user_id` with the value `1' OR '1'=1`. The response status is **400 Bad Request** (18 ms, 516 B). The response body, shown in JSON format, is:

```
{
  "status": "error",
  "message": "Bad Request: User ID must be a numeric value"
}
```

movies.php

The screenshot shows the same web browser interface, but the URL bar displays the request: `GET http://localhost/cinema_booking/api/movies.php?movie_id=1' OR '1'=1`. The "Params" tab is active, showing a query parameter `movie_id` with the value `1' OR '1'=1`. The response status is **200 OK** (29 ms, 650 B). The response body, shown in JSON format, is:

```
{
  "status": "success",
  "message": "Movie found",
  "data": {
    "movie_id": 1,
    "judul": "Batman",
    "durasi": 176,
    "rating_umur": "R13",
    "deskripsi": null,
    "genre": "Action",
    "status_tayang": "now_playing"
  }
}
```

showtimes.php

The screenshot shows a REST client interface with the following details:

- Method:** GET
- URL:** `http://localhost/cinema_booking/api/showtimes.php?showtime_id=1' OR '1'=1`
- Query Params:** A table with one entry:

Key	Value	Description
showtime_id	1' OR '1'=1	
- Body:** JSON response showing a successful status and movie details.

```
1 {
2   "status": "success",
3   "message": "Showtime found",
4   "data": {
5     "showtime_id": 1,
6     "movie_id": 1,
7     "studio_id": 1,
8     "jam": "19:00:00",
9     "tanggal": "2026-04-14",
10    "harga_tiket": "50000.00",
11    "judul": "Batman",
12    "genre": "Action",
13    "nama_studio": "Studio Gold VIP",
14    "nama_bioskop": "Tangerang XXI"
15  }
16 }
```
- Status:** 200 OK, 56 ms, 731 B

bookings.php

The screenshot shows a REST client interface with the following details:

- Method:** GET
- URL:** `http://localhost/cinema_booking/api/bookings.php?booking_id=1' OR '1'=1`
- Query Params:** A table with one entry:

Key	Value	Description
booking_id	1' OR '1'=1	
- Body:** JSON response showing a successful status and booking details.

```
1 {
2   "status": "success",
3   "message": "Booking found",
4   "data": {
5     "booking_id": 1,
6     "user_id": 1,
7     "showtime_id": 1,
8     "tanggal_booking": "2026-04-14 22:21:19",
9     "status_booking": "cancelled",
10    "user_name": "User Test",
11    "email": "test@gmail.com",
12    "no_hp": "081234567890",
13    "Jam": "19:00:00",
14    "Tanggal": "2026-04-14",
15    "Harga_tiket": "50000.00",
16    "movie_title": "Batman",
17    "nama_studio": "Studio Gold VIP"
18  }
19 }
```
- Status:** 200 OK, 44 ms, 1.24 KB

payments.php

My Collection > Get data

GET http://localhost/cinema_booking/api/payments.php?payment_id=1' OR '1'=1 Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

Query Params

Key	Value	Description	Bulk Edit	...
✓ payment_id	1' OR '1'=1			
Key	Value	Description		

Body Cookies Headers 11 Test Results 1/1 200 OK • 14 ms • 723 B Save Response

{ } JSON Preview Visualize

```
1 {
2   "status": "success",
3   "message": "Payment found",
4   "data": {
5     "payment_id": 1,
6     "booking_id": 1,
7     "metode_pembayaran": "OV0",
8     "total_bayar": "100000.00",
9     "status_pembayaran": "unpaid",
10    "tanggal_bayar": "2026-05-27 19:47:26",
11    "user_name": "User Test",
12    "email": "test@gmail.com"
13  }
14 }
```

Seats.php

My Collection > Get data

GET http://localhost/cinema_booking/api/seats.php?seat_id=1' OR '1'=1 Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

Query Params

Key	Value	Description	Bulk Edit	...
✓ seat_id	1' OR '1'=1			
Key	Value	Description		

Body Cookies Headers 11 Test Results 1/1 200 OK • 27 ms • 610 B Save Response

{ } JSON Preview Visualize

```
1 {
2   "status": "success",
3   "message": "Seat found",
4   "data": {
5     "seat_id": 1,
6     "studio_id": 1,
7     "baris": "A",
8     "nomor_kursi": "1",
9     "nama_studio": "Studio Gold VIP"
10  }
11 }
```

Seat_availability.php

My Collection > Get data

GET http://localhost/cinema_booking/api/seat_availability.php?showtime_id=1' OR '1'=1 Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

Query Params

Key	Value	Description	Bulk Edit	...
✓ showtime_id	1' OR '1'=1			
Key	Value	Description		

Body Cookies Headers 11 Test Results 1/1

200 OK • 35 ms • 827 B • Save Response

{ } JSON Preview Visualize

```
1 {
2   "status": "success",
3   "message": "Seat availability retrieved",
4   "data": [
5     {
6       "seat_availability_id": 1,
7       "showtime_id": 1,
8       "seat_id": 1,
9       "status_kursi": "booked",
10      "updated_at": "2026-05-27 20:02:21",
11      "baris": "A",
12      "nomor_kursi": "1"
13    },
14    {
15      "seat_availability_id": 2,
16      "showtime_id": 1,
17      "seat_id": 2,
```

studios.php

My Collection > Get data

GET http://localhost/cinema_booking/api/studios.php?studio_id=1' OR '1'=1 Send

Docs Params Authorization Headers 8 Body Scripts Settings Cookies

Query Params

Key	Value	Description	Bulk Edit	...
✓ studio_id	1' OR '1'=1			
Key	Value	Description		

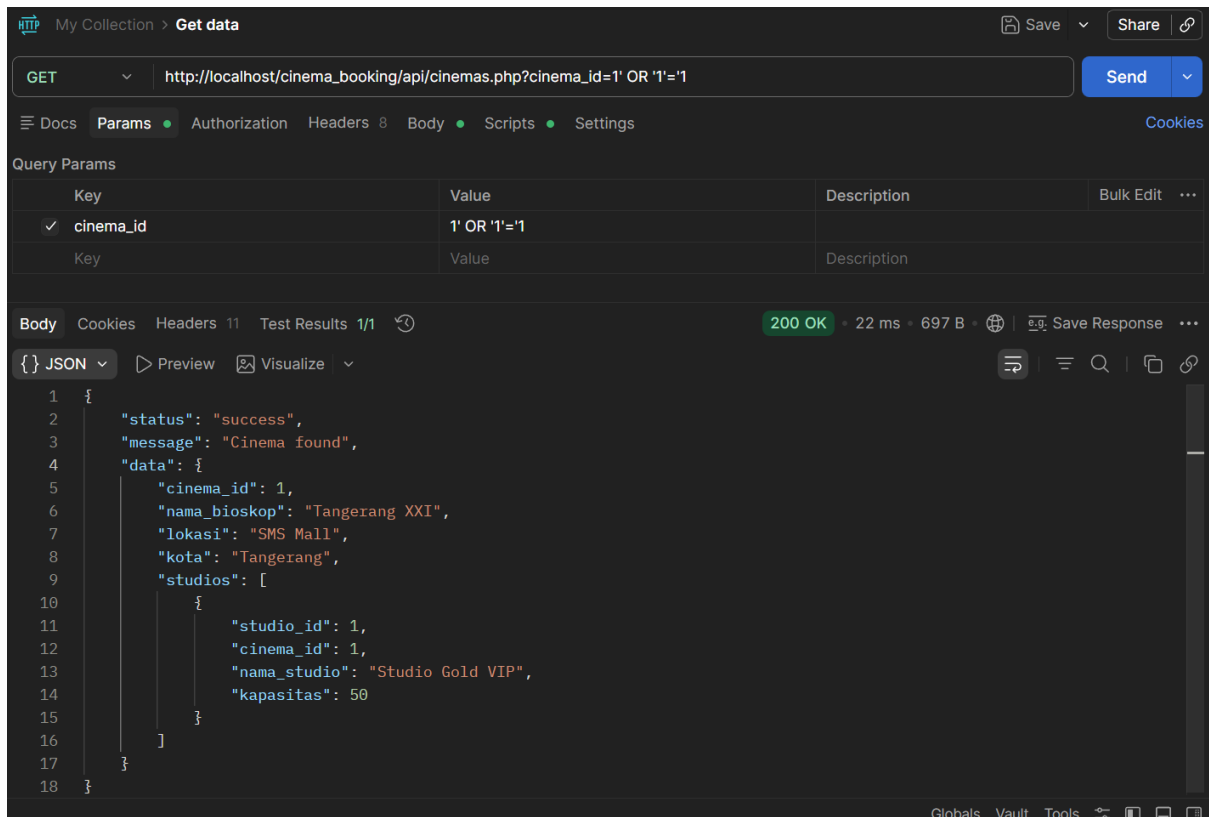
Body Cookies Headers 11 Test Results 1/1

200 OK • 34 ms • 872 B • Save Response

{ } JSON Preview Visualize

```
1 {
2   "status": "success",
3   "message": "Studio found",
4   "data": {
5     "studio_id": 1,
6     "cinema_id": 1,
7     "nama_studio": "Studio Gold VIP",
8     "kapasitas": 50,
9     "nama_bioskop": "Tangerang XXI",
10    "seats": [
11      {
12        "seat_id": 1,
13        "studio_id": 1,
14        "baris": "A",
15        "nomor_kursi": "1"
16      },
17      {
```

cinemas.php



Hasil

Berdasarkan pengujian SQL Injection pada seluruh endpoint API, sistem terbukti aman dari upaya manipulasi data. Respon sistem yang terbagi antara 400 Bad Request (akibat validasi input) dan 200 OK dengan data terisolasi (akibat PDO Prepared Statements), membuktikan bahwa mekanisme proteksi telah terimplementasi dengan baik di seluruh modul. Tidak ditemukan adanya kebocoran data massal, yang menandakan bahwa sistem telah berhasil memisahkan logika kueri dari input pengguna secara efektif. Dengan demikian, aplikasi ini dinyatakan stabil, aman, dan siap untuk digunakan.

Unit testing

